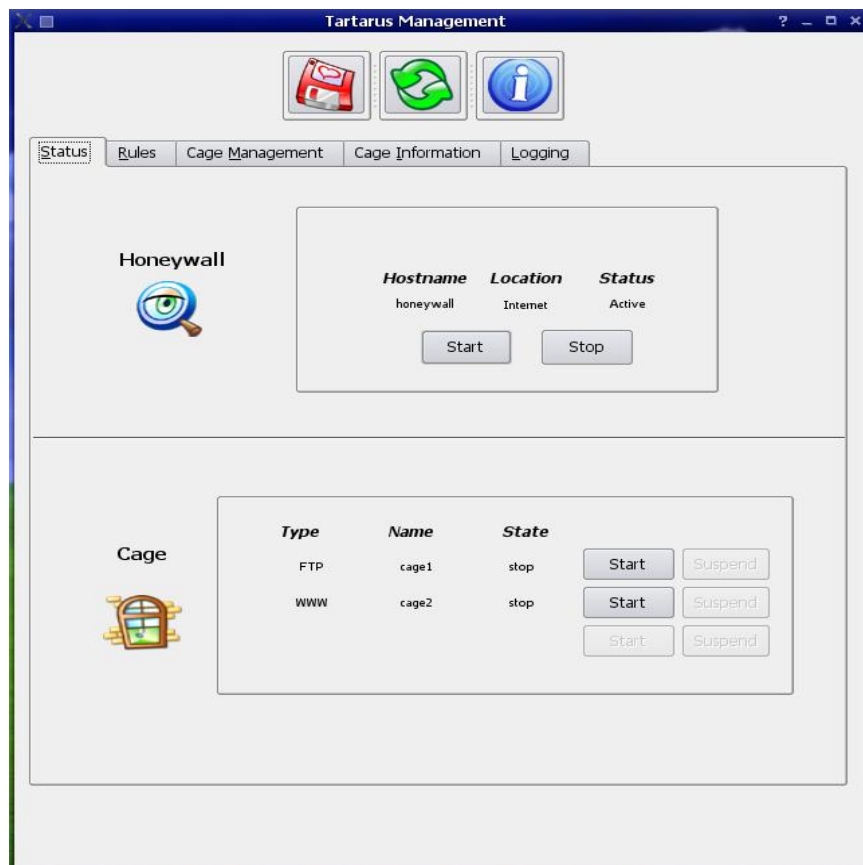


บทที่ 5

เครื่องมือที่พัฒนาขึ้นใหม่

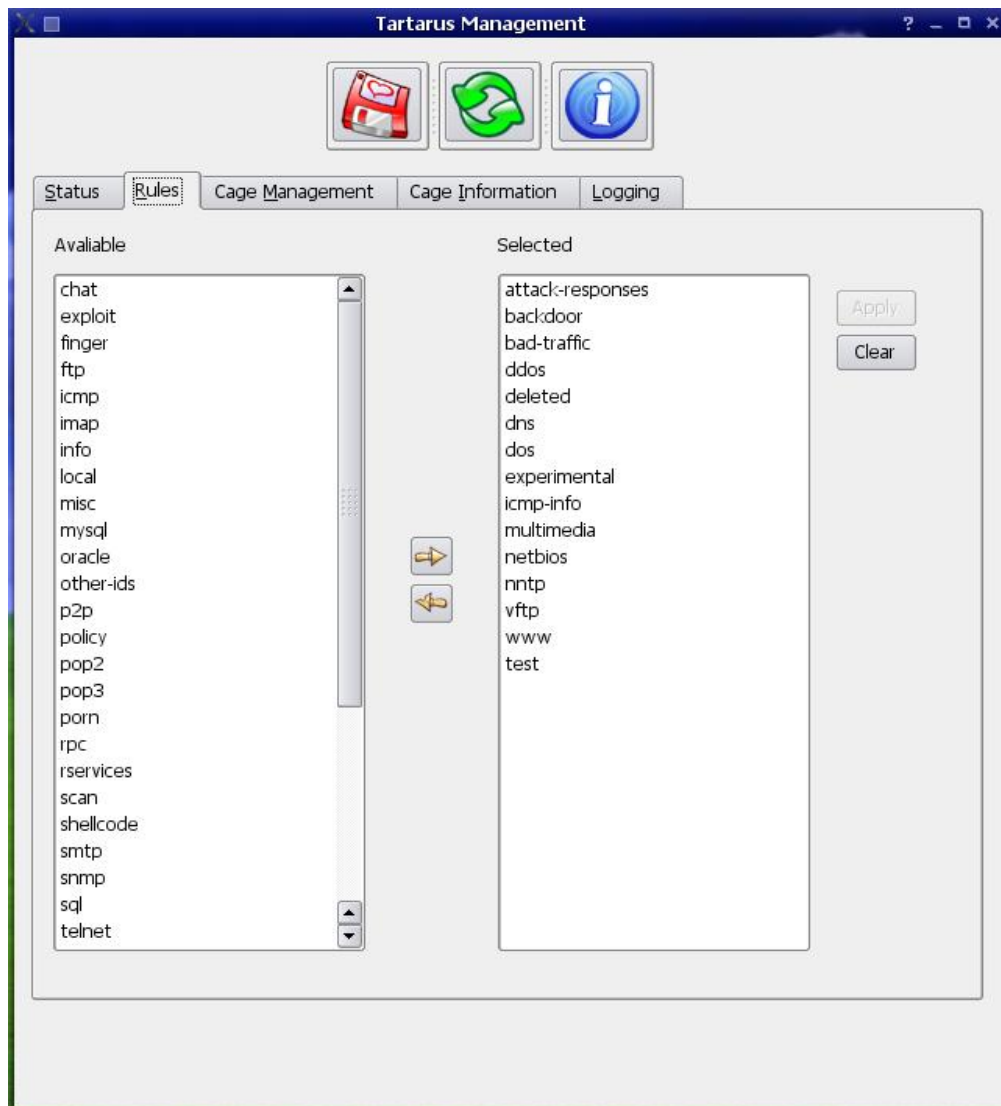
5.1 TM (Tartarus Management)

โปรแกรม Tartarus Management (TM) เป็นโปรแกรม Front-end ที่สร้างขึ้นเพื่อแก้ปัญหาความยุ่งยากในการดูแลและจัดการ ระบบฮันนีพ็อต ซึ่งมีเครื่องมือและองค์ประกอบที่ทำงานร่วมกันอยู่เป็นจำนวนมาก ซึ่งทำให้เกิดความยุ่งยากในการดูแลเครื่องมือต่างๆให้ทำงานร่วมกันอย่างมีประสิทธิภาพ โดยตัวโปรแกรมTMสามารถควบคุม และกำหนดค่าการทำงานของเครื่องมือทั้งหมดในชุดโปรแกรมจำแนกและบันทึกพฤติกรรมผู้บุกรุก โดยสามารถดูสถานะของระบบฮันนีพ็อตและความเป็นไปของเครื่องกับดัก และสามารถเรียกดูบันทึกพฤติกรรมของผู้บุกรุกที่เก็บบันทึกไว้ได้



รูปที่ 5.1 แสดงโปรแกรม TM (Tartarus Management)

โดยในหน้าแรกดังรูป 5.1 ที่อยู่ด้านบนจะเป็นส่วนที่แสดงสถานะของระบบตรวจจับผู้บุกรุกในเครื่องเกตเวย์และสถานะของเครื่องกับดัก ซึ่งสามารถสั่งเปิดและปิดระบบตรวจจับผู้บุกรุกและเปิดและปิดเครื่องกับดักได้



รูปที่ 5.2 แสดงรูปในส่วนที่ใช้ในการกำหนดกฎให้กับระบบตรวจจับผู้บุกรุก

ในรูป 5.2 เป็นส่วนของโปรแกรมที่ใช้ในการเพิ่มและลดกฎให้กับระบบตรวจจับผู้บุกรุกในเครื่องฮาร์ดแวร์เกตเวย์ ซึ่งจะเป็นกฎของตัว Snort inline โดยสามารถดาวน์โหลดกฎใหม่ๆ มาได้จากเว็บไซต์หลักของโปรแกรม Snort

Tartarus Management

Cage Information

Name:
 IP:

Path:
 Hostname:

Cage Configuration

☐ Number of Limit Users:

☐ Number User of Group "root":

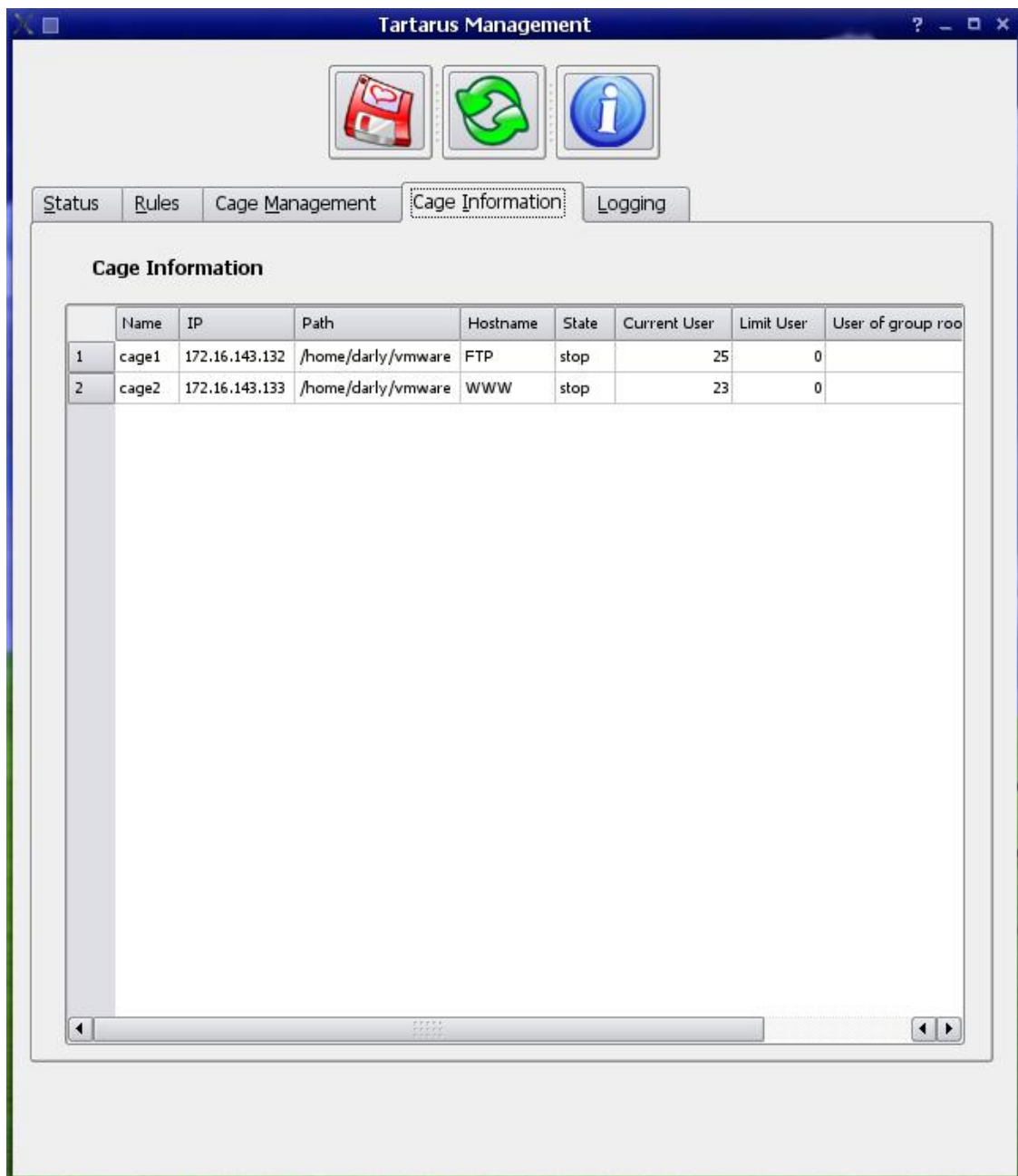
☐ Owner of file "/etc/passwd":

☐ Password root changed:

☐ Mode of file "/etc/passwd":

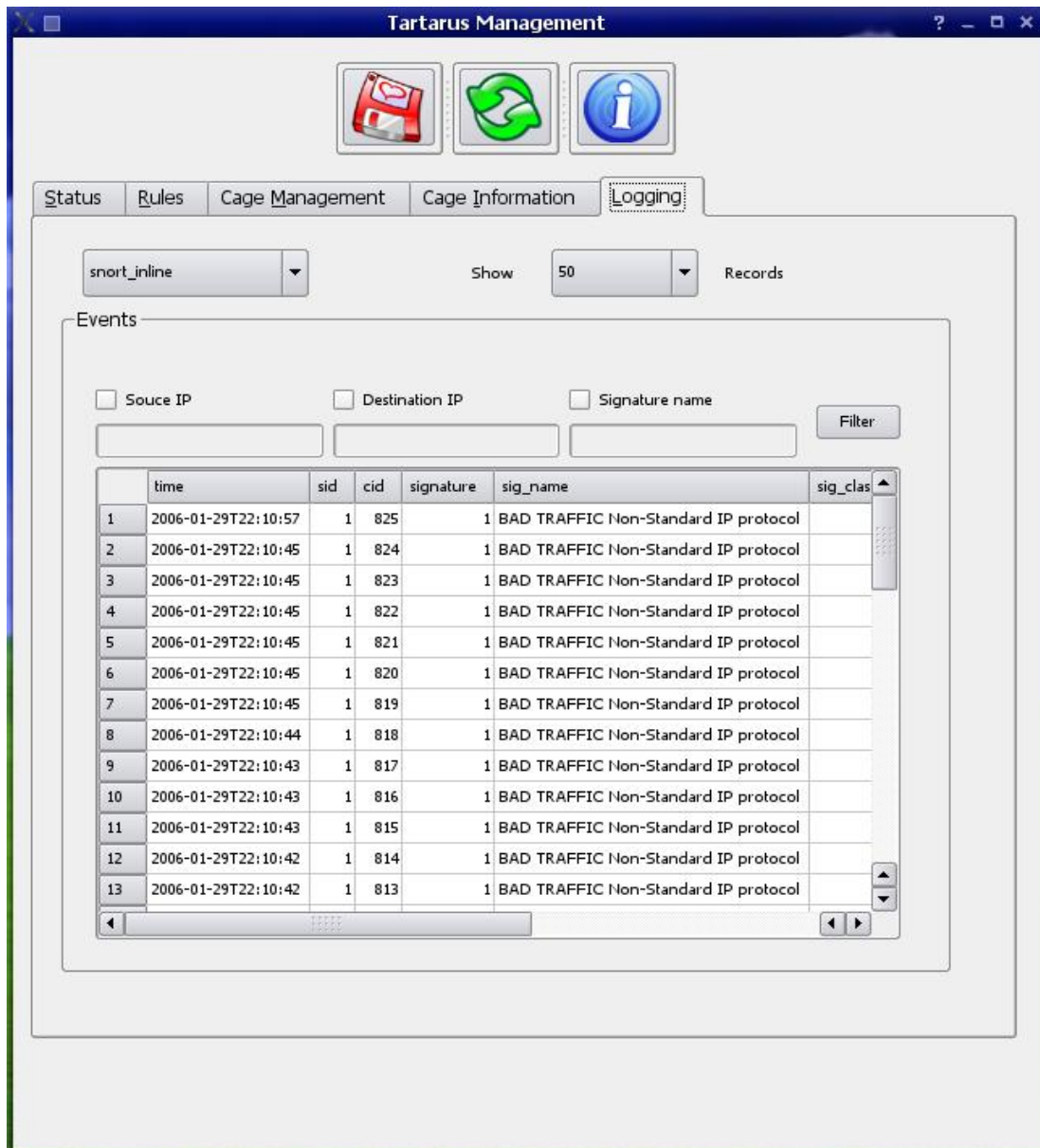
รูปที่ 5.3 แสดงส่วนจัดการเครื่องกับดัก

ในรูปที่ 5.3 เป็นส่วนที่ใช้ในการจัดการกับเครื่องกับดักทั้งในส่วนของการสร้าง ลบ เรียกดู ข้อมูลของเครื่องกับดัก และกำหนดการตรวจสอบเครื่องกับดัก ซึ่งจะช่วยให้ผู้ดูแลระบบไม่จำเป็นต้องเข้าไปตรวจสอบด้วยตัวเอง เพราะโปรแกรมจะทำการตรวจสอบให้โดยอัตโนมัติอยู่ตลอดเวลาในการใช้งาน



รูปที่ 5.4 แสดงข้อมูลของเครื่องกับดัก

จากรูปข้างต้นเป็นส่วนที่แสดงข้อมูลของเครื่องกับดักที่เก็บอยู่ในฐานข้อมูลในเครื่อง Logserver ซึ่งจะแสดงถึงชื่อ, หมายเลขไอพีแอดเดรส, สถานะ, พอร์ตที่เก็บเครื่องกับดัก และข้อกำหนดที่ใช้ตรวจสอบเครื่องกับดักนั้นๆ



รูปที่ 5.5 แสดง log ที่เก็บอยู่ในฐานข้อมูลในเครื่อง Logserver

จากรูปแสดงหน้าที่ใช้ในการดูข้อมูล log ที่เก็บอยู่ในฐานข้อมูลในเครื่อง Logserver ซึ่งจะประกอบด้วยข้อมูลที่ได้จากโปรแกรม snort_inline, โปรแกรม samhain และโปรแกรม sebek ซึ่งทั้ง 3 โปรแกรมนี้จะทำการเก็บบันทึกที่แตกต่างกัน

Sebek จะทำการบันทึกการกระทำของผู้กรุก เช่น keystroke, ข้อมูลการนำเข้า หรือ ส่งออก, ไฟล์ที่ได้นำเข้าหรือส่งออก

Samhain จะทำการบันทึกการเปลี่ยนแปลงของไฟล์ต่างๆ ในเครื่องกับดัก ซึ่งจะทำให้ทราบผลจากคำสั่งของผู้บุกรุกว่าไปมีผลต่อไฟล์ใด หรือทำการแก้ไข หรือลบไฟล์ใด

Snort inline จะทำการบันทึกข้อมูลของชิ้นข้อมูลที่มีการส่งผ่านเครื่อง Honeywall ที่ทำงานเป็นเกตเวย์ของระบบ

5.2 Cage Prototype

เครื่องกับดักในโครงงานนี้จะประกอบด้วยเครื่องที่ทำหน้าที่เป็น HTTP server และเครื่องที่ทำหน้าที่ FTP server โดยในที่นี้จะทำเป็นตัวอิมเมจของโปรแกรมวิเอ็มแวร์ซึ่งสามารถทำการคัดลอกไปใช้ได้เรื่อยๆ และเครื่องกับดักนั้นได้พัฒนาให้มีความแนบเนียนมากขึ้นโดยการเพิ่มสคริปต์ที่เขียนขึ้นเพื่อไม่ให้ผู้บุกรุกตรวจสอบพบว่าเครื่องที่ผู้บุกรุกกำลังทำงานอยู่ด้วยนั้น แท้จริงแล้วไม่ใช่เครื่องให้บริการจริง โดยได้แก้ไขคำสั่งทั่วไปที่ผู้บุกรุกจะใช้ตรวจสอบ เช่น

- ifconfig เป็นคำสั่งที่ใช้ในการแสดงตัวตนซึ่งจะแสดง ip address, MAC Address และรายละเอียดอื่นๆ ซึ่งโดยปกติแล้วถ้าใช้คำสั่ง ifconfig แล้วผู้บุกรุกจะทราบว่าตนเองไม่ได้อยู่ในเครื่องที่เป็นเครื่องแม่ข่ายจริงๆ ซึ่งในที่นี้ได้เขียนสคริปต์เพื่อไปเปลี่ยนแปลงผลลัพธ์ที่ได้จากการใช้คำสั่ง ifconfig ให้แสดงข้อมูลของเครื่องแม่ข่ายจริง ทำให้ผู้บุกรุกไม่ทราบว่าตนเองถูกส่งให้เข้าไปอยู่ในเครื่องกับดักแล้ว
- ping เป็นสคริปต์ที่ใช้ในการส่ง icmp packet ยังเครื่องอื่นๆ ซึ่งโดยปกติแล้วถ้าใช้คำสั่ง ping ไปยังเครื่องที่ไม่ได้เปิดอยู่จะขึ้น message error ว่า Host Unreachable และจะแสดงไอพีแอดเดรสของเครื่องที่ใช้คำสั่ง ping ด้วย ซึ่งก็จะทำให้ผู้บุกรุก รู้ว่าตนเองไม่ได้อยู่ในเครื่องแม่ข่ายจริง เช่นเดียวกับ ifconfig และในที่นี้ได้เขียนสคริปต์เพื่อเปลี่ยนแปลงผลลัพธ์ที่ได้จากการใช้คำสั่ง ping ให้แสดงไอพีแอดเดรสของเครื่องแม่ข่ายจริงเพื่อไม่ให้ผู้บุกรุกทราบว่าถูกส่งเข้าไปยังเครื่องกับดักแล้ว
- route เป็นคำสั่งที่แสดง routing table ซึ่งถ้าผู้บุกรุกใช้คำสั่งนี้ก็จะทราบได้ว่าตนเองไม่ได้อยู่ในเครื่องแม่ข่ายเช่นกัน ดังนั้นในที่นี้ได้เขียนสคริปต์เพื่อไปเปลี่ยนแปลงผลลัพธ์ที่ได้จากคำสั่ง route เพื่อผู้บุกรุกไม่สามารถทราบได้ว่าตนเองถูกส่งไปยังเครื่องกับดักแล้ว
- netstat เป็นคำสั่งที่ใช้ดูการเชื่อมต่อต่างๆ ว่ามีการเชื่อมต่อเข้ามาจากภายนอกหรือไม่ หรือมีการเชื่อมต่อจากภายในออกไปยังภายนอกหรือไม่ และมีพอร์ตใดเปิดอยู่บ้าง